DATHEON / APPLICATION SECURITY

Task 1 — IDOR Discovery Report

Datheon Application Security & API Pentesting Internship · 30 October–27 November 2026

Adil Firoz · Batch 01 · The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

LOCAL SYNTHETIC-DATA TRAINING PORTFOLIO

Task 1 — IDOR Discovery Report

Adil Firoz · Datheon Application Security & API Pentesting Internship · Batch 01

The Neotia University · B.Tech Computer Science and Engineering (Cybersecurity)

Assessment type: Local controlled demonstration with synthetic data

Executive summary

This assignment demonstrates how an object identifier can be changed to access a synthetic record when authorization is omitted, then compares it with a secure owner-checked endpoint. The intentionally vulnerable route is opt-in, checks a loopback Host and client socket, and is unavailable in production. No live service was assessed.

Objectives and scope

- Perform a bounded reconnaissance of the local API route map and identifiers.
- Compare unauthenticated and cross-user requests against vulnerable and secure routes.
- Observe HTTP statuses and response bodies using cURL, Postman, and browser Developer Tools.
- Keep all activity inside the localhost synthetic-data application.

Architecture and tools

Node.js, TypeScript, Express, Supertest/Vitest, cURL, Postman, and Chrome Developer Tools. The API has two fictional student users and in-memory records. GET /api/task1 documents the endpoint map.

Methodology and implementation

The vulnerable demonstration at GET /api/task1/vulnerable/records/:id intentionally selects a record by identifier alone. The comparison endpoint requires a valid session and returns a record only when both the identifier and authenticated user ID match. The route guard requires the explicit ENABLE_VULNERABLE_IDOR_DEMO=true setting, a loopback Host and client socket, and a non-production environment.

Test procedure and results

The automated integration suite asserts that the local vulnerable demonstration exposes the other synthetic record, while the remediated endpoint requires authentication and denies cross-user access with 404. The generated result below is taken from the Vitest JSON report produced by npm test.

Execution result: See the generated PDF's “Automated test execution” section for the measured run status. A test failure is reported as a failure and is not described as passing.

Manual cURL example:

```
curl -i http://127.0.0.1:3000/api/task1/vulnerable/records/rec_2002
```

The vulnerable route is disabled unless deliberately enabled locally. After login, Alice's attempt to fetch rec_2002 from the secure route must return 404.

Risk assessment

Illustrative CVSS 3.1 vector for a hypothetical unauthenticated, remotely reachable read-only weakness exposing

high-confidentiality records: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N = 7.5 High. This score is not a finding against Datheon or any third-party system and is not representative of the local fixture's impact.

Evidence

No screenshots were taken during the automated run. Do not treat generated or sample images as evidence. Capture the local browser Network panel, Postman, and cURL results manually as described in ../evidence/README.md.

Remediation and conclusion

Authorize every object read using the authenticated principal and object ownership, not the caller's ability to guess an identifier. Keep responses consistent for absent and unauthorized objects. The secure implementation and regression test are the baseline for this training exercise.

References

- OWASP API Security Top 10 — API1: Broken Object Level Authorization.
- FIRST, Common Vulnerability Scoring System v3.1 Specification.
- OWASP Web Security Testing Guide — Authorization Testing.

Automated test execution

Vitest run: PASSED · 8/8 passed · 0 failed

Test case	RESULT	Duration
Task 1 and Task 2: object authorization keeps the vulnerable route disabled unless explicitly enabled	PASSED	128 ms
Task 1 and Task 2: object authorization keeps the vulnerable comparison reachable only on loopback with the explicit lab flag	PASSED	15 ms